

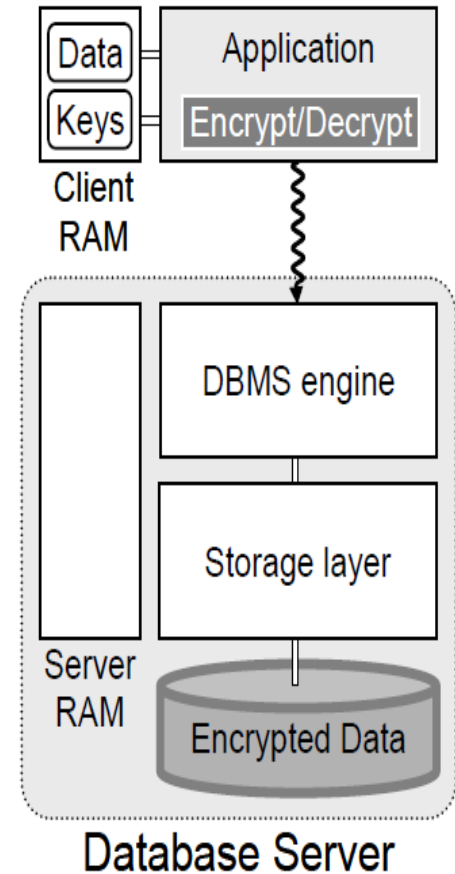
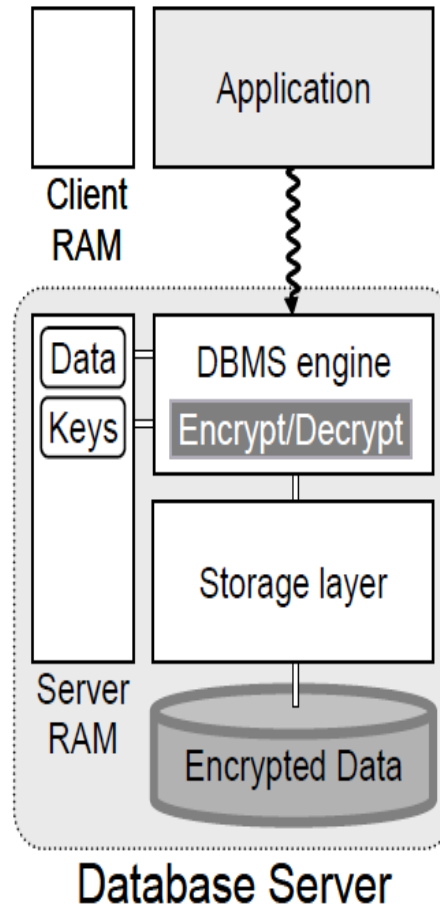
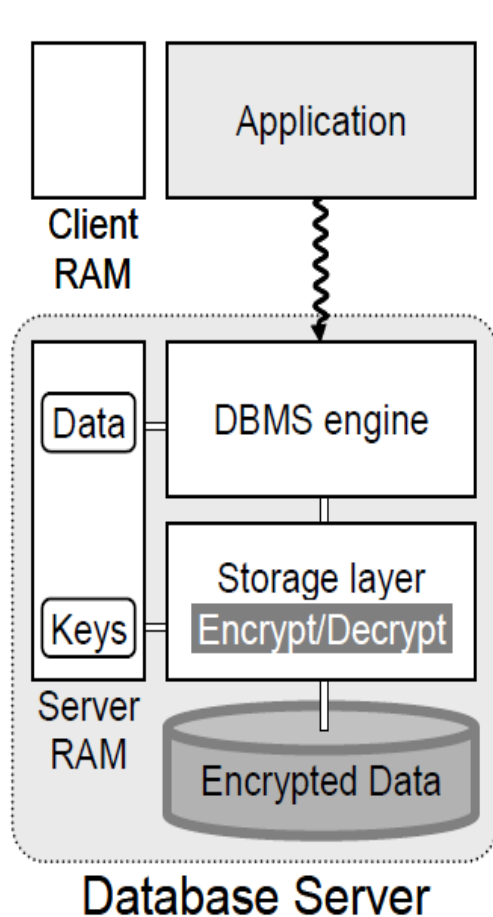
ИББД2

Лекция 1

Направления по ЗИ в СУБД

- Физическая защита и контроль доступа к серверам и помещениям;
- **Контроль входных и выходных значений;**
- Контроль потоков данных
- Удаленные подключения через VPN;
- Безопасность сетевого окружения.
- Разграничение доступа к БД
- **Шифрование данных**
- Резервное копирование данных
- Аудит и мониторинг

Шифрование на различных уровнях СУБД



a. Storage-level encryption

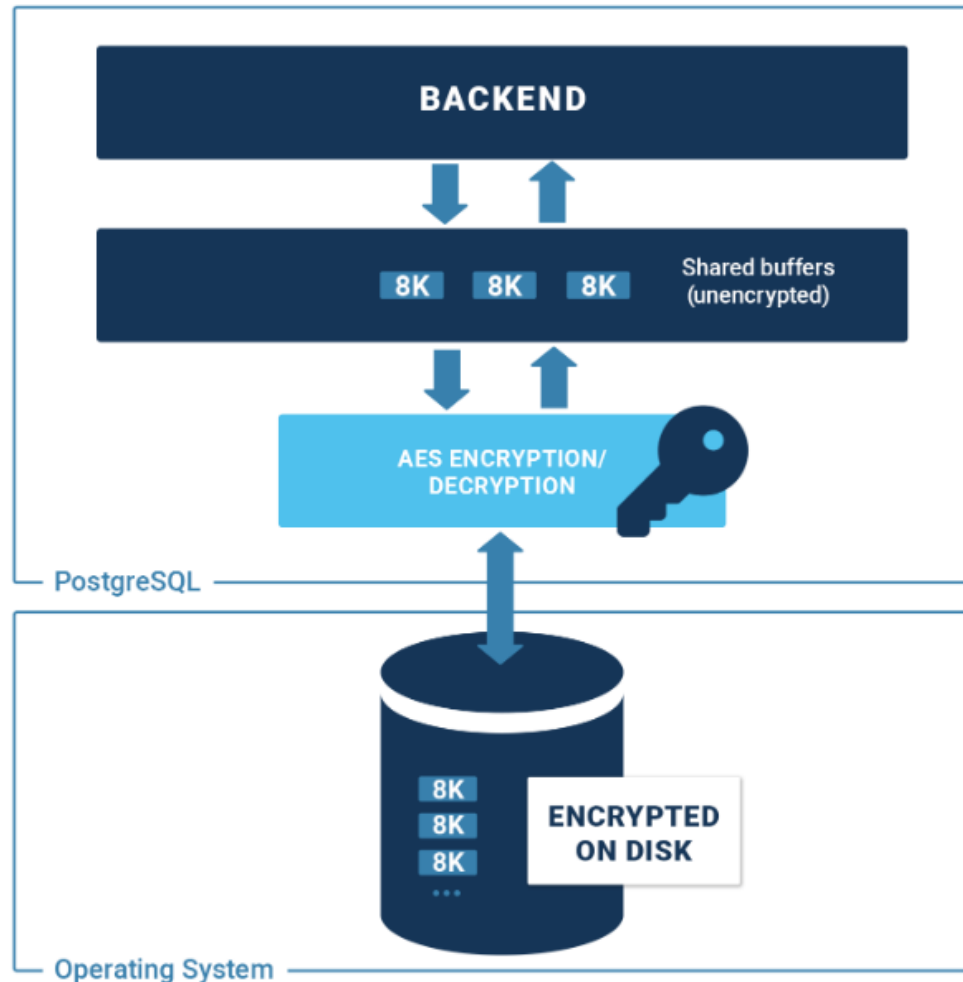
b. Database-level encryption

c. Application-level encryption

Функция Always Encrypted

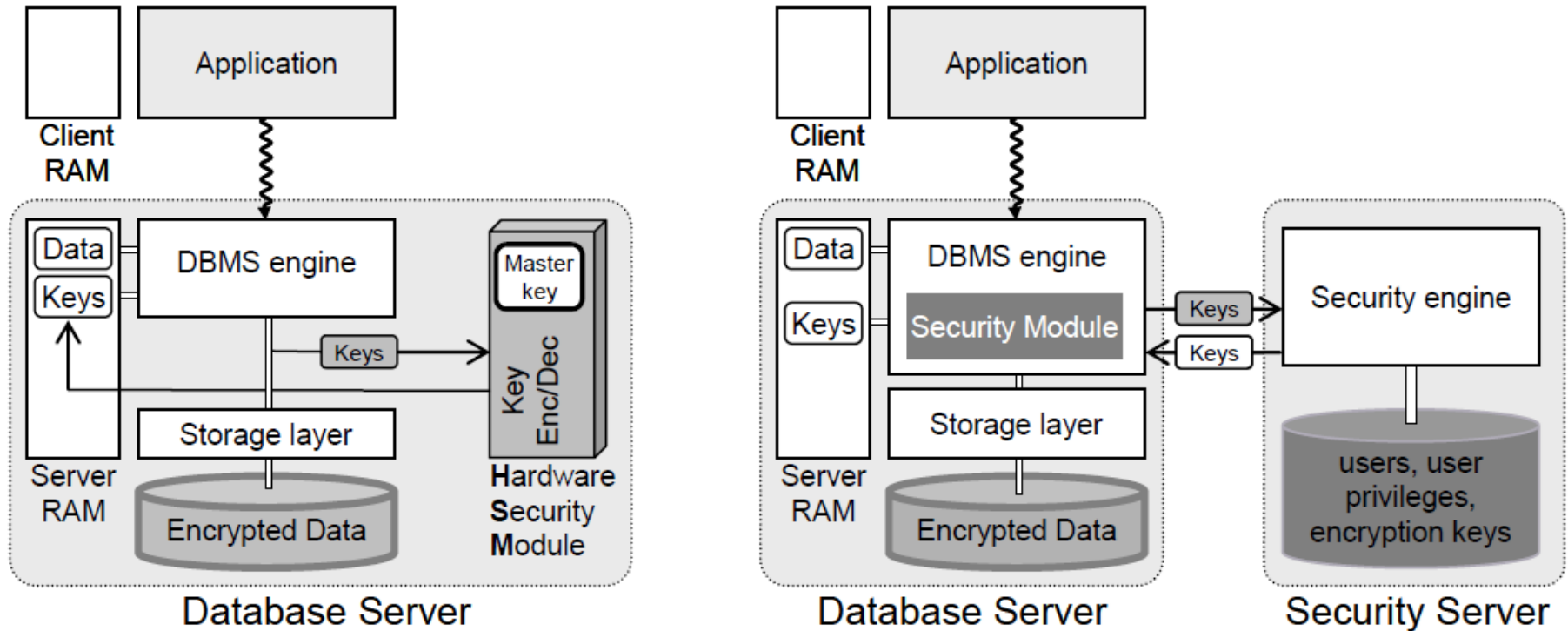


Прозрачное шифрование данных (TDE)



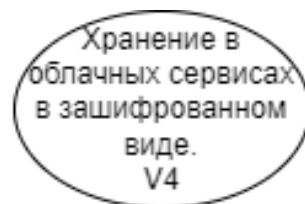
- Шифрование средствами ОС
- Шифрование аппаратными средствами

Хранение и резервирование ключей



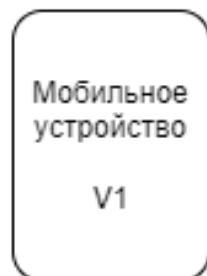
- Программные криптоконтейнеры
- Аппаратные токены (usb-накопители, диски)
- Материальные носители (запоминалки, от руки написанные замаскированные/зашифрованные значения в сейфе)
- Облачные хранилища
- Комбинированные решения на основе схем разделения секрета и подобных им криптопримитивов.
- Хранение криптографических ключей в переменных окружения ПО

Комбинированные решения на основе схем разделения секрета



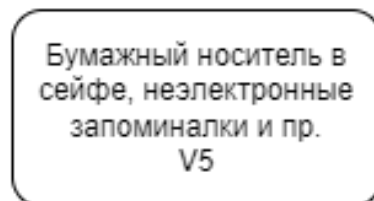
Внешние ресурсы
относительно
организации

.....



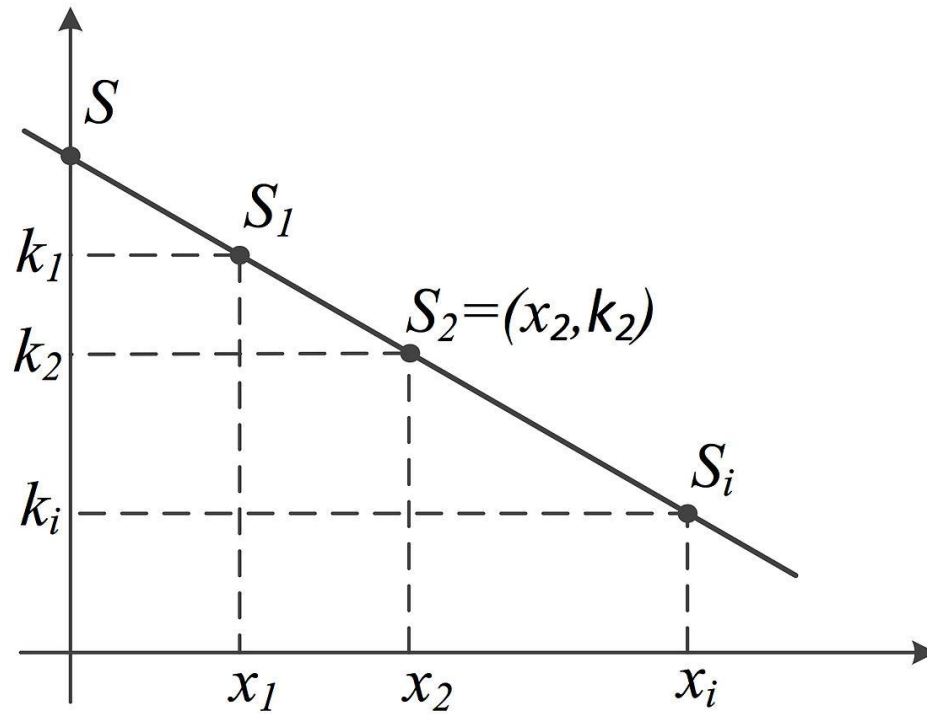
Личное пространство
лиц, ответственных за
ключи

.....



Физически
защищенный
периметр

Схемы разделения секрета. Принцип работы



Базовые ограничения при использовании шифрования

Критерий сравнения	Системы идентификации и аутентификации	Асимметричные криптосистемы	Симметричные криптосистемы
Основные функции	Создают аутентифицированный канал для асимметричных криптосистем	Безопасно передают, распределяют, согласуют криптографические ключи для симметричных криптосистем	Шифруют/дешифруют основной объем данных
Ограничения при использовании	Имеют вероятность ложных срабатываний, ошибки в реализации и хранения данных для аутентификации и т.д.	Безопасно работают только в каналах с аутентификацией	Безопасно работают только если одинаковый ключ распределен между сторонами
Примеры	аутентификация/идентификация по паролю, токenu, биометрия	ДХ, RSA, Эль-Гамаль	AES, ГОСТ 34.12, IDEA

Контроль выходных значений БД.

Анонимизация и обезличивание данных в БД.

«**Обезличивание данных**» (ФЗ №152) «действия, в результате которых становится невозможным без использования дополнительной информации определить принадлежность персональных данных конкретному субъекту персональных данных»

«**Анонимизация**» (Европейский GDPR) не имеет аналогичных терминов в российском законодательстве и означает, что даже при использовании дополнительной информации невозможно идентифицировать субъект персональных данных.

Зачем необходимо обезличивать?

- Требования регуляторов;
- Статистические базы данных, которые публикуются либо отдаются для анализа сторонним организациями
- Тестовые базы данных для разработчиков/тестировщиков



Методы анонимизации данных

Европейские специалисты в области информационной безопасности выделяют в NIST SP800-122 такие методы псевдонимизации, как:

- **абстрагирование или обобщение**, т. е. персональные данные становятся менее точными, например, с помощью группировки, замены абстрактным значением или усреднения;
- **скрытие**, т. е. персональные данные удаляются полностью или частично во избежание избыточности по отношению к цели псевдонимизации;
- **добавление шума**, т. е. в персональные данные добавляется посторонняя информация;
- **разделение на части**, т. е. персональные данные делятся на несколько таблиц и хранятся отдельно;
- использование **специальных алгоритмов**, к которым относятся криптографические преобразования (шифрование, хеширование, генерация случайных значений различных форматов, генерация ключей), а также маскирование персональных данных или замена отдельных символов другими (кодирование).

Стратегии маскирования

Атрибут	Стратегия маскирования	Функция
Имя	Замена правдоподобной альтернативой	Динамическая seed таблица
Фамилия	Замена правдоподобной альтернативой	Динамическая seed таблица
Пол	Без изменений	N/A
Отчество	Без изменений или удаление	Без изменения
Дата рождения	Замена правдоподобной альтернативой, сохраняя возраст	Сдвинуть дату
ИНН	Замена правдоподобной альтернативой	хэш
Семейное положение	Без изменений	N/A
Строки адресов	Замена правдоподобной альтернативой из КЛАДР	Seed таблица адресов
Телефон	Замена правдоподобной альтернативой	Маскировать телефон
Email	Замена правдоподобной альтернативой	Маскировать email
ID документа	Перестановка или замена	Хэш
Номер карты	Перестановка или замена	Хэш

Отечественные методы обезличивания

Приказ Роскомнадзора №996 утверждает четыре метода обезличивания, к которым относятся:

- метод введения идентификаторов;
- метод декомпозиции;
- метод изменения состава и семантики
- метод перемешивания

PostgreSQL Anonymizer

```
=# SELECT * FROM people;  
id | firstname | lastname | phone  
-----+-----+-----+-----  
T1 | Sarah    | Conor   | 0609110911
```

Step 1 : Activate the dynamic masking engine

```
=# CREATE EXTENSION IF NOT EXISTS anon CASCADE;  
=# SELECT anon.start_dynamic_masking();
```

Step 2 : Declare a masked user

```
=# CREATE ROLE skynet LOGIN;  
=# SECURITY LABEL FOR anon ON ROLE skynet IS 'MASKED';
```

Step 3 : Declare the masking rules

```
=# SECURITY LABEL FOR anon ON COLUMN people.lastname  
-# IS 'MASKED WITH FUNCTION anon.fake_last_name()';  
  
=# SECURITY LABEL FOR anon ON COLUMN people.phone  
-# IS 'MASKED WITH FUNCTION anon.partial(phone,2,$$*****$$,2)';
```

Step 4 : Connect with the masked user

```
=# \connect - skynet  
=> SELECT * FROM people;  
id | firstname | lastname | phone  
-----+-----+-----+-----  
T1 | Sarah    | Stranahan | 06*****11
```